

# Zero-Trust-Sicherheitskonzept mit GitHub-Integration

Certified IT Business Manager (IHK) – Sommer 2026

Daniel Massa · Prüflingsnummer 615951

Verein zur Förderung der Berufsbildung e.V., Ludwigsburg

1 / 10

## Ausgangssituation & Problem

- ▶ Manuelle Rechtevergabe per E-Mail (35 Anträge/Woche)
- ▶ **3,2 Tage** durchschnittliche Bearbeitungszeit
- ▶ **8–12 %** Fehlerquote → 15 Nachbesserungen/Monat
- ▶ Dezentrale Audit-Logs – Compliance-Prüfungen erschwert
- ▶ Keine Self-Service-Funktionen für Mitarbeiter
- ▶ DSGVO-Risiken durch unklare Verantwortlichkeiten

## Projektziele (SMART)

### Spezifisch:

RBAC mit 10+ Rollen, 50+ Berechtigungen

### Messbar:

Bearbeitungszeit <4h · Fehlerquote <2 %

### Akzeptiert:

Pilot mit 15 Nutzern

### Realistisch:

70 h IHK-Rahmen

### Terminiert:

01.11.2026

- ✓ **Reduktion** Bearbeitungszeit: 3,2d → <4h
- ✓ **Reduktion** Fehlerquote: 10 % → <2 %
- ✓ **100 %** Audit-Abdeckung

# Projektplanung

## Ressourcen

- ▶ 70 h Aufwand (IHK-Vorgabe)
- ▶ 3.740 EUR Budget
- ▶ Hybrides Vorgehen (Wasserfall + agil)
- ▶ 8 Meilensteine, 15 Arbeitspakete

## Risikomanagement

- ▶ 7 Risiken identifiziert & bewertet
- ▶ Top-Risiko: Fehlkonfiguration (Wert 15)
- ▶ Gegenmaßnahmen: 4-Augen-Prinzip, Policy-Checks, Secret-Scanning

# Zero-Trust & RBAC-Konzept

*"Never Trust, Always Verify"*

– NIST SP 800-207

- ▶ 6 Rollen definiert
- ▶ Admin · Developer · Auditor
- ▶ Read-Only · HR-Manager · Finance
- ▶ Least-Privilege-Prinzip
- ▶ DSGVO-Konformität (Art. 5, 25, 32)

## Make-or-Buy-Entscheidung:

Nutzwertanalyse: GitHub-Prototyp (4,1) vs. IAM (3,7) vs. manuell (2,4)

✓ **Eigenentwicklung gewählt**

# GitHub Workflow

Automatisierte Rechtevergabe in 4 Stufen:

## ① **Validate**

Pflichtfelder- & Policy-Prüfung

## ② **Approve**

Genehmigungsanfrage an Vorgesetzten

## ③ **Provision**

GitHub-API: Teamzuordnung

## ④ **Notify**

Statusbenachrichtigung per E-Mail

Jeder Schritt:

- ✓ Automatisiert getriggert
- ✓ Im Audit-Log protokolliert
- ✓ Fehlerbehandlung integriert

# Prototyp-Umsetzung

## Technologie-Stack

- ▶ Frontend: React.js / TypeScript
- ▶ Backend: FastAPI (Python)
- ▶ Datenbank: PostgreSQL
- ▶ CI/CD: GitHub Actions
- ▶ Auth: Azure AD / SAML
- ▶ Container: Docker

## Ergebnisse

- ✓ **12/12 Testfälle bestanden**
- ✓ **92,4 % Code Coverage**
- ✓ **Secret-Scan: 0 kritische Funde**
- ✓ **DSGVO-Checkliste vollständig**

# Test & Abnahme

## Testfallmatrix

- ▶ TF01-04: Antrags-Workflow
- ▶ TF05-06: Policy-Engine
- ▶ TF07-08: Rechtevergabe/-entzug
- ▶ TF09: Audit-Log
- ▶ TF10: Secret-Scanning
- ▶ TF11-12: Export & Benachrichtigung

## Abnahme

- ✓ **Alle Muss-Kriterien erfüllt**
- ✓ **Abnahmeprotokoll unterzeichnet**
- ✓ **Soll-Ist-Vergleich: alle Ziele erreicht**

## Wirtschaftlichkeit

### Kosten

Projektleitung: 3.150 EUR

Beratung: 340 EUR

Tools: 250 EUR

**Gesamt: 3.740 EUR**

### Nutzen

Jährliche Einsparung: **13.000 EUR**

Amortisation: **3,5 Monate**

ROI (3 Jahre): **340 %**

# Lessons Learned & Ausblick

## Erfolgsfaktoren

- ▶ Iterative Entwicklung mit kurzen Feedback-Zyklen
- ▶ Frühzeitige Einbindung von DSB & Betriebsrat
- ▶ GitHub Actions als flexible Plattform

## Optimierung

- ▶ Realistischere Zeitplanung
- ▶ Frühere Einbindung Security-Partner

## Ausblick

- ▶ KI-basierte Anomalieerkennung 2027
- ▶ Integration HR & Verwaltung
- ▶ Kontinuierliche Security-Assessments

*Vielen Dank für Ihre Aufmerksamkeit!*